BPFDOOR-DEFENSE

BPFDoor 백도어와 리눅스 탐지

연관 기출 · 137-4-1

한눈에 이해

열린 수신포트만 확인하는 점검으로 조용히 대기하는 백도어를 놓칠 수 있어 프로세스·소켓·패킷·파일 증거를 결합합니다.

정의와 핵심 원리

BPFDoor는 리눅스의BPF기반 패킷필터등을 악용하여 특정 네트워크트래픽을감시하고 명령·후속연결을 활성화하는백도어계열로알려져있습니다. 정상BPF기능자체와악성사용을구분해야합니다.

• 전통적고정포트listen형백도어와달리항상 눈에띄는수신포트가없어도 트리거패킷을 관찰하는구조가 가능합니다. 따라 서포트스캔결과하나로감염없음을보장할 수 없습니다. 변종별프로세스위장·지속성·통신 동작은 다를 수 있습니다.

• 위협은 서버명령실행·자격증명및정보 탈취·측면이동·서비스 가용성훼손입니다. 관리자 권한·raw socket·BPF관련사용과예상외실행파일·삭제된실행파일·비정상통신·지속성 설정을 조합해조사하고 정상운영 도구와 구별합니다.

• 대응은 자산과공식 점검 범위 확인 → 의심호스트격리 → 휘발성·디스크·로그 증거 보존 → 감염·침입 경로파악 → 비밀·세션 회수 → 깨끗한재구축·취약점제거 → 재검증입니다. 일괄삭제·재부팅으로증거를 잃거나원격접속을영구상실하지 않도록업무 복구와 연계합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
포트listen형	고정연결대기흔적	포트·소켓관측
패킷트리거형	특정 패킷 감시후활성화	포트점검만 으로부족
다층조사	프로세스·파일·네트워크	시간·변종·오탐검증

적용 예제

포트가 정상인 의심 서버

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 외부이 상통신관측;평상시포트목록변화없음

1. 공식가 이드와서버역할을대조해의심증거를 보존합니다.
2. 실행 경로·권한·소켓·프로세스 관계를 분석합니다.
3. 동일계정과 인접서버의 원격접근이 력을추적합니다.
4. 발견된변종의지속성·초기침입을 제거후복구합니다.

결과·해석: 단일IOC나포트검사보다 다층증거와 원인 제거로대응합니다.

전제·주의: KISA2025-05-12공지직접 열람.첨부가 이드전문·변종별IOC는 미열람이며 특정 명령·해시검출의완전성을주장하지 않습니다.

답안 골격과 혼동 방지

기능과 악용구분 → 기존 백도어비교 → 위협 영향 → 기술·관리 대응 → 증거·복구

- 모든 BPF프로세스를 악성으로분류하지 않습니다.
- 점검스크립트음성을절대무감염증명으로쓰지않습니다.

내용을 가리고 회상

1. 수신포트없음이무감염을뜻하지 않는이유는무엇입니까?
2. 정상BPF와 악성활동을어떻게구분합니까?
3. 격리전후증거 보존의 우선순위는무엇입니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- BPFDoor 악성코드 점검 가이드 공지 - KISA KrCERT/CC; 2025-05-12; 확인 2026-11-05.
- NIST SP800-86 Integrating Forensics into Incident Response - Karen Kent et al. / NIST; 2006-08; 확인 2026-11-05.
- MITRE ATT&CK TA0008 Lateral Movement - MITRE; 최종수정 2025-08-11; 확인 2026-11-05.